

OSI model layer	OSI model name	Function	Protocols	Words to remember	Hardware Equipment	Equipment Purpose	PDU (Protocol Data Unit)	TCP/IP Model	Hybrid Model	Pentest Vulnerability Examples
7	Application	This layer supports application and end-user processes. Communication partners are identified, quality of service is identified, user authentication and privacy are considered, and any constraints on data syntax are identified. Everything at this layer is application-specific. This layer provides application services for file transfers, e-mail, and other network software services. Telnet and FTP are applications that exist entirely in the application level. Tiered application architectures are part of this layer.	HTTP (80,8080), HTTPS (443), TFTP (69), FTP (20, 21), IMAP (143), SMTP (25), POP3 (110), SSH (22), Telnet (23), DNS (53), DHCP (67,68)	User interface, Application, Browser, Represent data to user	Computer, Gateway, Firewall	Regular computer or special gateway used to combine network using different communication protocols, filtering traffic	APDU (Encoded)	Application	Application	Injection flaws (SQLi, command, LDAP): user input concatenated into queries/commands → data exfiltration, auth bypass, RCE. Tools: sqlmap, Burp. Broken authentication & access control (IDOR): modifying ? user_id=123 → 124, default creds on Telnet/FTP/SNMP, missing authorization on API endpoints.
6	Presentation	This layer provides independence from differences in data representation (e.g., encryption) by translating from application to network format, and vice versa. The presentation layer works to transform data into the form that the application layer can accept. This layer formats and encrypts data to be sent across a network, providing freedom from compatibility problems. It is sometimes called the syntax layer.	MIME, XDR, SSL, ASCII/EBCDIC, JPEG, MP3	Data format, Coding, Conversion, Compression, Language, Decryption, Encoding, Encryption	Computer, Gateway redirector		PPDU Charter		Application	Weak TLS/SSL configuration: SSLv3, TLS 1.0/1.1, weak ciphers (RC4, DES), POODLE, BEAST, Heartbleed, ROBOT. Detect with testssl.sh, sslyze. Improper certificate validation: self-signed/expired certs accepted, missing cert pinning in mobile apps, shared wildcard certs → MITM despite "HTTPS being used".
5	Session	This layer establishes, manages and terminates connections between applications. The session layer sets up, coordinates, and terminates conversations, exchanges, and dialogues between the applications at each end. It deals with session and connection coordination.	NFS, SQL, RPC, Named Pipes, NetBIOS, SAP	User session (Establish, Restart, End), Dialogues, Data exchange	Computer, Gateway		SPDU		Data link	NetBIOS / SMB NTLM relay: when SMB signing isn't enforced, attacker relays captured NTLM auth to another host (Responder + ntlmrelayx). Classic internal-pentest finding. Session fixation / weak session management: predictable or attacker-supplied session IDs, sessions that never expire, session IDs leaked via URL parameters.
4	Transport	This layer provides transparent transfer of data between end systems, or hosts, and is responsible for end-to-end error recovery and flow control. It ensures complete data transfer.	TCP: transaction control protocol 20 bytes Protocol 6 UDP: User datagram 8 bytes Protocol 17	TCP, UDP, Process address, Segment, Encapsulation, Reassemble, Decapsulation	Computer, Advanced cable tester, Brouter		TPDU Segment	Transport	Transport	SYN flood (DoS): half-open TCP connections exhaust the server's connection table → service unavailability. Relevant when SYN cookies / rate limiting aren't in place. TCP session hijacking & exposed services: predictable sequence numbers, unencrypted sessions (Telnet, FTP); aggressive nmap scans reveal services that should be firewalled (DB ports from user VLAN).
3	Network	This layer provides switching and routing technologies, creating logical paths, known as virtual circuits, for transmitting data from node to node. Routing and forwarding are functions of this layer, as well as addressing, internetworking, error handling, congestion control and packet sequencing.	IPv4 (32bits), IPsec, IPX, IPv6, RIP, Apple talk, ICMP, ARP (48 bits), BGP, RARP	Route, static or dynamic, congestion ctrl, IP, best path, Logical address, quality of service	Router, Brouter, Frame relay device, ATM switch	Segment network into smaller broadcast domains.	packets	Internet	Network	IP spoofing & ICMP-based attacks: forging source IPs to bypass ACLs, smurf amplification, ICMP tunneling/exfiltration (icmpsh, ptunnel) past firewalls allowing outbound ping. Routing protocol abuse: unauthenticated RIP/OSPF/BGP advertisements injected on LAN → route poisoning, MITM at L3. BGP hijacking is the internet-scale version.
2	Data Link	At this layer, data packets are encoded and decoded into bits. It furnishes transmission protocol knowledge and management and handles errors in the physical layer, flow control and frame synchronization. The data link layer is divided into two sub layers: The Media Access Control (MAC) layer and the Logical Link Control (LLC) layer. The MAC sub layer controls how a computer on the network gains access to the data and permission to transmit it. The LLC layer controls frame synchronization, flow control and error checking.	Circuit switching, Packet switching, Ethernet, WIFI, Token Ring, ATM, FDDI, Frame Relay, WAN, HDLC, LLC 802.2, MAC 802.3, 802.5, PPP, PPTP, L2TP	transmission errors, MAC medium access control, Flow control, Error check, Circuit switching, Packet switching, Framing, CRC, Physical address, WPA, WEP	Bridge, Switch, NIC, ISDN router, Intelligent hub	Segment network into smaller collision domains	frames	Host to network	Data link	ARP spoofing / poisoning: forged ARP replies associate attacker's MAC with the gateway's IP → MITM, credential theft, SSL stripping. Tools: arpspoof, bettercap, ettercap. VLAN hopping (double-tagging / switch spoofing): crafted 802.1Q frames or DTP impersonation bypass segmentation (e.g. guest VLAN → server VLAN). Also: MAC flooding, rogue DHCP.
1	Physical	This layer conveys the bit stream – electrical impulse, light or radio signal – through the network at the electrical and mechanical level. It provides the hardware means of sending and receiving data on a carrier, including defining cables, cards and physical aspects. Fast Ethernet, RS232, and ATM are protocols with physical layer components.	Bits, RS 232, V .35, T1, E1, ISDN, POTS, SONET, DSL, EIA/TIA	Bits, volts, 1 or 0, Cabling, nanoseconds, transmission directions, pins, Connector mechanical, electrical, timing and physical properties.	Repeaters, Hubs, Multi-port cabling, Multiplexer, TDR hubs, Oscilloscope, Amplify	One collision and one broadcast domain.	Bit		Physical	Unsecured network ports / rogue device drops: open Ethernet jacks in lobbies/printers/IP phones replaced with drop devices (Raspberry Pi, LAN Turtle) → internal access. Common where 802.1X is absent. Cable tapping & hardware keyloggers: physical taps on unshielded cabling, USB/PS2 keyloggers between keyboard and PC → cleartext capture. Trivial where datacenter/closet physical security is weak.